

PivoxQuant 변호사 자문 패키지 (v2.3)

- 작성일: 2026-05-04 (v2 → v2.3 2026-05-05 sync)
- 버전: **v2.3** (2026-05-05) – v2.2 → safe_scrub merge 91fd01c + autotrader 물리 삭제 4bcc9ab + cross_border 체크박스 c9c6827 반영. 상세는 §8 변경 이력 참조.
- 작성자: 배상현 (1인 창업자, 대표이사 후보)
- 회의 형태: 1회 대면(50~80만원), 후속 follow-up 가능
- 본 패키지는 **현 코드/문서 grep 검증 결과**를 인용한 사실 진술서이며, 변호사 판단을 받기 위한 사전 준비 자료다. 본인 의견(추측)은 따로 표시한다.

§0 회사 개요 (Read-First, 1 page)

0-1. 회사

- 상호: PivoxQuant (구 StockPilot, 2026-04-15 리브랜딩)
- 도메인: pivoxquant.com (가비아 등록, 2026-04 19,800원/년)
- 사업자등록: **미등록 상태** (변호사 자문 후 부친 명의 vs 본인 명의 결정 예정)
- 1인 운영(대표 = 개발 = 디자인 = 마케팅), 외부 직원 0명

0-2. 서비스 본질

- B2C SaaS 정보 제공 도구. 개인 투자자가 **자기 자신의** 매매·자기점검을 위해 사용하는 PFM(Personal Finance Management) 류의 도구
- AI 어시스턴트(Anthropic Claude API) + 퀀트 스코어링 + 페이퍼 트레이딩(시뮬레이션) + 자기 점검 PDF 산출물
- 3티어 SaaS: Free / Pro 9,900원 / Premium 19,900원 (월, 부가세 포함)
- 결제: Stripe (사업자등록·통신판매업 신고 후 라이브 결제 활성화 예정)

0-3. 핵심 결정 (이미 CEO 확정)

- 유사투자자문업 신고 X – 자본시장법 §101 면제 트랙(Personal Capital 모델) 유지
- 자동매매(**autotrader**) 제거 – 2026-04-27 코드 비활성화 (routes/__init__.py line 16~22, 71)
- **KIS read-only** – 한투 주문 API 영구 비활성 (services/kis/service.py line 489~528)
- Alpaca BYOK + 시스템 ALPACA_ENABLED kill switch OFF 기본값 (config.py line 69)

0-4. 본 자문에서 받고자 하는 것

1. 위 결정 4가지의 **법적 안전성 사인**(Yes/No + 근거)
2. 출시(D-Day) 전 추가 의무 항목 명시
3. 약관/처리방침 한국어 ACTIVE 전환 가능 여부

4. 회색지대 기능 (아래 §2) 의 출시 가능 여부 + 조건

§1 핵심 결정 (사인 받기)

1-1. 유사투자자문업 미등록 결정 (자본시장법 §101)

항목	회사 입장
결정	신고/등록 하지 않음
근거	"Personal Capital" 모델 – 사용자가 자기 자신의 데이터(자기 포트폴리오, 자기 매매 의도)를 자기 자신을 위해 분석하는 도구. 불특정 다수 대상의 투자조언/리포트 배포 행위 없음. 1:1 맞춤 자문 행위 없음.
코드 근거	grey-zone PDF 5종은 모두 <code>generate_for_user(user_id)</code> / <code>generate_for_position(user_id, ticker)</code> 진입점만 가짐. 즉 본인 user_id 인증 필수 + 본인의 보유 종목/매매 의도 기반에서만 생성.
면책 문구	모든 산출물 말미 한/영 disclaimer 자동 첨부 (<code>services/legal_filter.py:169-170</code>)

→ 변호사 사인 요청: §2 Q1 참조

1-2. 자동매매 제거 결정 (자본시장법 – 투자일임업)

항목	상태
루트 <code>autotrader.py</code> 파일	삭제됨
<code>services/trading/autotrader.py</code> (1,321 lines <code>AutoTrader</code> 클래스)	물리 삭제 완료 – commit <code>4bcc9ab</code> (2026-05-05)
<code>routes/autotrade.py</code> (279 lines)	물리 삭제 완료 – 동일 commit
<code>routes/__init__.py</code> <code>autotrade</code> blueprint 등록	삭제 완료 – 잔존 주식 0건
<code>app.py</code> <code>AutoTrader</code> boot 호출	삭제 완료 – 잔존 주식 0건
<code>services/container.py</code> <code>init_trader()</code> no-op	함수 자체 삭제 – <code>trader=None</code> 변수도 제거
프론트엔드 <code>/autotrade</code> 페이지	제거됨
후속 cleanup	<code>tests/test_autotrade_smoke.py</code> 삭제 – commit <code>d8088c7</code> (<code>autotrader</code> 물리 삭제 후 <code>dangling import</code> 검증 테스트만 남아있던 잔재)
Rollback 가능성	<code>git tag legal-pre-autotrader-removal</code> 만 (push 됨) – 코드 잔존 0건. 복원 시 <code>git checkout legal-pre-autotrader-removal -- services/trading/autotrader.py routes/autotrade.py</code> + 주변 호출 코드 직접 복원 필요

1-3. KIS read-only (한국투자증권 API)

`services/kis/service.py:489-528` 발췌:

```
def buy_order(self, ticker: str, quantity: int, price: int = 0, order_type: str = "00"):
    """DISABLED -- KIS order execution is read-only for legal compliance.
    한투 주문 실행은 투자일임업(자본시장법) 규제로 영구 비활성화됨.
    """
    return {
        "ok": False,
        "error": "KIS order execution is disabled. Please use the KIS app to place orders.",
    }

def sell_order(self, ticker: str, quantity: int, price: int = 0, order_type: str = "00"):
    """DISABLED -- KIS order execution is read-only for legal compliance.
    한투 주문 실행은 투자일임업(자본시장법) 규제로 영구 비활성화됨.
    """

def _place_order(self, ticker: str, quantity: int, price: int, order_type: str, side: str):
    """DISABLED -- order execution removed for legal compliance (자본시장법).
    KIS order execution is permanently disabled. ...
    """
```

- 잔여 주문 관련 함수: `get_order_status` (line 532) – **조회 전용**(체결 내역 read-only). 매매 실행 X.
- 사용자가 실제 매매를 하려면 한투 앱에서 직접 입력해야 함.

1-4. Alpaca BYOK + 시스템 kill switch OFF

`config.py:45-69` :

```
# ALPACA_ENABLED – kill switch for SYSTEM-WIDE Alpaca usage (server-owned keys).
# This server-side ALPACA_ENABLED flag therefore stays OFF in production.
ALPACA_ENABLED = os.environ.get("ALPACA_ENABLED", "0").strip() in ("1", "true", "True", "TRUE", "yes")
```

`routes/broker_oauth.py` (kill switch 적용 6곳: 정의 line 309-327, status endpoint 가드 line 260, endpoint 가드 4곳 line 365/414/435/451):

- `_alpaca_kill_switch_response()` 함수가 `ALPACA_ENABLED=False` 시 503 반환.
- 시스템 키 Alpaca 호출 경로는 production에서 모두 503.
- 사용자 BYOK 경로는 별도(UI 미완 – 미출시 상태).

→ 변호사 사인 요청: 위 1-2 / 1-3 / 1-4 가 §6 미등록 투자업 · §101 영업행위 중 어느 카테고리 도 트리거하지 않는지.

§2 변호사 판단 요청 – 12개 질문

각 질문 구조:

- a. 회사 현재 포지션 (코드/UX/문서 근거)
- b. 증거 파일 경로 + 라인번호 (실제 grep 으로 확인)
- c. 변호사 판단 요청 (Yes/No + 근거 + 추가 의무 + 위험 등급)

Q1. 자본시장법 §101 면제 적정성 (Personal Capital 모델)

a. 현재 포지션

- 회사는 유사투자자문업 신고를 하지 않는다 (CEO 결정 2026-05-04).
- 근거: Personal Capital 모델 - 사용자 자기 자신의 데이터(자기 보유 종목, 자기 매매 의도) 한정, 불특정 다수 대상 정보 제공 없음.
- 모든 분석/스코어링은 사용자가 직접 로그인 후 자기 user_id 컨텍스트에서 자기 자신을 위해 사용.

b. 증거

- `services/legal_filter.py:1-25` - 모듈 docstring에 "자본시장법 §6 미등록 투자자문업 + §101 불공정 영업행위 리스크 방어선" 명시.
- `services/legal_filter.py:36-155` - 89개 정규식 `_REPLACEMENTS` + 6개 `_PROHIBITED` + 1개 `_COMPLIANCE` 정규식(총 96개 `re.compile`).
- `frontend/src/content/terms-ko.md:89-106` (제6조 - 투자자문 면책):

본 서비스(PivoxQuant)는 「자본시장과 금융투자업에 관한 법률」상 투자자문업 또는 투자일임업이 아닙니다.

- `~/ .claude/projects/-Users-seanbae-Desktop---/memory/legal_decision_no_advisory.md`
- CEO 결정 메모.

c. 판단 요청

- (1) §101 면제 트랙(Personal Capital 모델)이 자기 데이터 한정 PFM으로 인정되는지.
- (2) "분석 시그널"(POSITIVE/NEGATIVE/NEUTRAL)이 §101의 "불특정 다수 대상 투자조언" 정의에 포섭되는지.
- (3) 회사가 "자기 데이터" 경계를 어느 수준까지 유지해야 면제 범위 내인지(예: 백테스팅 화면, Discover 페이지의 시그널 리스트가 self-data인지 universe-data인지).
- (4) 위험 등급 (회사 자체 평가): HIGH (잘못 판단 시 §101 위반 + 형사 처벌 + 서비스 섯다운).

Q2. 회색지대 5 PDF - 자기 데이터 한정 면제 충분성

a. 현재 포지션

회사는 5종 PDF 모두를 사용자 본인 user_id 컨텍스트에서만 생성. 외부 배포·구독 모델 아님. 모든 PDF에 면책 문구 첨부.

PDF	입력 데이터
<code>earnings_prebrief</code>	사용자 보유 종목 + 결산 일정
<code>credit_rating</code>	사용자 포트폴리오의 5요인 점수(0~100)
<code>insider_mirror</code>	사용자 보유 종목 관련 인사이더 거래 필링
<code>year_end_letter</code>	사용자 본인 1년 매매 회고
<code>pre_trade_checklist</code>	사용자 매매 직전 self-check 7질문

b. 증거 (file:line)

`services/artifacts/year_end_letter_service.py:16-17, 28, 456`

```
- **Download for the owner only** (PDF email + in-app download).
- Dollar / Won amounts are allowed in the user's *own* copy because
  they are reading their own book; the renderer must not surface ...
def generate_for_user(self, user_id: int, target_year=None) ...
```

services/artifacts/earnings_prebrief_service.py:6, 154, 184-188

```
EarningsPreBriefService().generate_for_position(user_id, ticker, earnings_date)
user_id: int # required
```

services/artifacts/credit_rating_service.py:5, 12, 106

```
CreditRatingService().generate_for_user(user_id, as_of=None) → data dict
Scores the user's portfolio on five deterministic factors (0-100 each)
user_id: int
```

services/artifacts/insider_mirror_service.py:9, 20, 27

```
P1 Weekly summary – count of filings related to holdings.
APScheduler day_of_week=mon, hour=9 KST. Empty holdings → ...
```

services/artifacts/pre_trade_checklist_service.py:1-3

```
"""Pre-Trade Checklist – persona-tailored 7-question self-check.
매매 전 **자기점검용 양식** (Tools, not advice). 사용자가 직접 ..."""
```

c. 판단 요청

- (1) 위 5종이 모두 "자기 데이터 한정" 요건을 충분히 충족하는지.
- (2) credit_rating의 5요인 점수(0~100)가 "투자등급"으로 해석돼 신용평가업(자본시장법) 트리거할 가능성.
- (3) earnings_prebrief(특정 종목의 결산 직전 정리)가 "특정 종목 분석 리포트 발행"으로 해석돼 §101 위반 가능성.
- (4) insider_mirror(SEC EDGAR Form 4 데이터 가공)가 데이터 재배포 위반 가능성.
- (5) year_end_letter(작년 매매 회고)에 통화·금액 표시 가능 여부 – 본인 한정이라도 추후 외부 공유될 위험.
- (6) 위험 등급 (회사 자체): MEDIUM-HIGH.

Q3. 마이데이터 법 (신용정보법 §22의9)

a. 현재 포지션

- BYOK(Bring Your Own Key) + read-only 모델 → "개인용 도구" 포지셔닝.
- Alpaca(미국 broker, BYOK), KIS(한국 broker, BYOK + read-only).
- 회사는 사용자 자격증명을 암호화 저장 후 사용자 본인 위임으로 read-only 조회만 수행. 매매 실행 X.
- 회사는 "본인신용정보관리업" (자본금 5억) 인가 받지 않을 계획.

b. 증거

- services/kis/service.py:489-528 – 주문 API 영구 비활성, 조회 전용.

- routes/broker_oauth.py:255-453 - Alpaca 시스템 kill switch.
- frontend/src/content/terms-ko.md:182 (제9조 3항):

외부 데이터 제공자 BYO(Bring Your Own Key) 원칙 일부 외부 데이터 제공자(예: Alpaca)에 대하여 회사는 사용자가 직접 발급받은 API 키를 통해 데이터를 조회·전달하는 방식만을 운영합니다.

- ~/.claude/projects/-Users-seanbae-Desktop---/memory/legal_compliance.md:40-61 - 마 이데이터 우려 메모(2026-04-28 작성, 변호사 답 미수령).

c. 판단 요청

- (1) BYOK + read-only "개인용 도구"가 본인신용정보관리업 §22의9 적용대상인지(인가·면허 필요 여부).
- (2) Alpaca(해외 broker) 정보가 한국 신용정보법 적용 외인지 - 조회 데이터가 한국 사용자 단말로 들어오는 시점에 적용될 가능성.
- (3) KIS(국내 broker)는 read-only여도 "통합 조회/관리" 사업이면 적용되는지.
- (4) 다중 broker(Alpaca + KIS) 통합이 §22의9가 정의한 "여러 기관에서 신용정보 통합" 기준에 해당하는지.
- (5) 회사가 이 모델을 유지하려면 어떤 조치(고지, 동의, 약관)가 필수인지.
- (6) 위험 등급 (회사 자체) HIGH (인가 필요로 판정 시 자본금 5억 트리거, 1인 창업자에게 사실상 섣다운).

Q4. 국외 이전 동의 (PIPA §28-8)

a. 현재 포지션

- 인프라 4곳이 모두 미국 호스팅: Anthropic PBC(Claude API), Stripe(결제), Vercel(프론트), Railway(백엔드 + DB).
- 처리방침 §6에 위탁 표 + §6-1에 국외 이전 표가 있고 명시적으로 §28-8을 인용함.
- 회원가입 화면에는 동의 체크박스 4개(terms / non_advisory / age / marketing)만 있고 **국외 이전 동의 별도 체크박스가 없음**.

b. 증거

frontend/src/content/privacy-ko.md:181-201 (제6조 ① 국외 이전):

수탁자	국가	이전 항목	이전 목적	보유 기간
Stripe, Inc.	미국	결제 정보, 이메일, 청구서 정보	결제 처리 및 청구	거래 종료 후 5년
Anthropic, PBC	미국	AI 채팅 내용 (이메일·이름 제외)	Claude AI 응답 생성	요청 처리 후 즉시 삭제 (30일 이내 로그)
Railway Corp.	미국 (Oregon)	서버 데이터 전체	애플리케이션 호스팅	서비스 이용 기간
Vercel Inc.	미국	접속 로그, IP 주소, User-Agent	정적 자원 배포 및 오태 캐싱	30일
Google LLC (OAuth)	미국	이메일, 이름, 프로필 사진	OAuth 로그인 인증	로그인 토큰 유효 기간 (1시간), refresh

- 본인은 「개인정보 보호법」 제28조의8에 따른 안전조치를 이행합니다.

frontend/src/app/(auth)/signup/_v2/page-v2.tsx (commit c9c6827, 2026-05-05)

```
interface Consents {
  terms: boolean;
  non_advisory: boolean;
  age: boolean;
  cross_border: boolean; // PIPA §28-8 - 필수 (2026-05-05 추가)
  marketing: boolean; // 정통방법 §50 - 선택
}
setAllRequired(
  consents.terms && consents.non_advisory && consents.age && consents.cross_border,
);
```

→ **5번째 체크박스 추가됨** - `cross_border` (필수). 미체크 시 OAuth 가입 버튼 disabled. localStorage staging snapshot에 포함되어 OAuth 콜백 `flushPendingCrossBorderConsent()` 가 백엔드 POST `/api/consents/cross-border` 로 명시 동의 시각을 영구 기록. backend는 `migration 024_cross_border_consent.py` + `User.cross_border_consent_at/_revoked_at` 컬럼 + 3 endpoints (GET / POST / DELETE) 모두 적용됨.

c. 판단 요청

- (1) 처리방침 게시 + "이용자께서는 서비스 가입 시 아래 이전에 동의한 것으로 간주" 문구만으로 §28-8의 "별도 동의" 요건을 충족하는지 (통상 별도 명시 동의 체크박스 필요로 해석).
- (2) Anthropic Claude API에 사용자 채팅 내용을 전송하는 행위가 "민감정보의 국외 이전"으로 가중 동의 필요한지.
- (3) Google OAuth는 한국에 사업 거점이 있는데도 §28-8 적용대상인지.
- (4) Kakao Corp.는 한국 소재라 위탁(국내), Google은 미국 소재라 국외 이전 - 이 분류가 정확한지.
- (5) 5번째 체크박스 추가 시 통과 시점은 회원가입 단계 vs 첫 사용 단계 어느 쪽이 적합한지.
- (6) 위험 등급 (회사 자체): HIGH (PIPA 위반 시 과태료 + 행정처분).

Q5. 이용약관 13개 조항 한국어 검수 (DRAFT → ACTIVE 전환)

a. 현재 포지션

- terms-ko.md = 244 lines / 13개 조항 (1조 ~ 13조 + 부칙). 문서 첫 줄 `status: "DRAFT"` - 최종 시행 전 변호사 검토 필요.
- privacy-ko.md = 346 lines / 12개 조항 (1조 ~ 12조 + 부칙).
- 회사 v1 메모리 (legal_compliance.md:21-23)에는 "약관 18조항 / 처리방침 14조항"으로 기록되어 있으나, 현재 코드 상에서는 13조 + 12조. 메모리 outdated, 검증 결과 사실 (§6-1 참조).

b. 증거

- `frontend/src/content/terms-ko.md:7` - `status: "DRAFT - 최종 시행 전 변호사 검토 필요"`
- 조항 헤더 grep 결과 (이용약관):
제1조(목적) / 제2조(용어의 정의) / 제3조(약관의 효력 및 변경) / 제4조(회원가입 및 자격) / 제5조(회원의 의무) / 제6조(서비스 이용 - 투자자문 면책) / 제7조(시그널 및 AI Assistant 면책) / 제8조(유료 서비스) / 제9조(콘텐츠 저작권) / 제10조(회원의 책임) / 제11조(회사의 책임 제한) / 제12조(분쟁 해결) / 제13조(문의처) / 부칙
- 처리방침 조항 헤더 grep 결과:
제1조 ~ 제12조 + 부칙

c. 판단 요청

- (1) DRAFT 워터마크 제거 가능 시점 (조건부 가능 / 무조건 가능 / 추가 수정 후 가능).

- (2) 18개 → 13개로 축약된 부분이 누락 조항인지(예: 미성년자 보호, 손해배상 절차, 광고 표시 등).
 - (3) 시행일자, 사업자등록번호, 사업자 명의(부친 vs 본인) 확정 시 부칙 기재 방식.
 - (4) 약관 변경 시 30일 사전 통지 외 추가 의무.
 - (5) **위험 등급 (회사 자체)**: MEDIUM (전자상거래법 §6 위반 가능성, 14일 환불기간 표시 등).
- §3 인라인 인용 참조.

Q6. 회원탈퇴 시 거래기록 보존 (전자상거래법 §6 vs PIPA §37)

a. 현재 포지션

- 전자상거래법 시행령 §6: 결제·청약철회 등 거래기록은 5년 보존 의무.
- PIPA §37: 정보주체의 처리정지 요구권 – 회원탈퇴 시 즉시 파기 원칙.
- 두 법령이 충돌. 회사는 아직 회원탈퇴 시 결제 정보 보존/즉시 파기 정책을 확정하지 않음.

b. 증거

- `frontend/src/content/privacy-ko.md:114-140` (제4조 보유 기간) – 항목별 보유기간만 기재, 회원탈퇴 후 결제기록 별도 5년 보존 명시는 변호사 검토 필요.
- `HANDOVER_2026-05-04.md:59` – "legal #11 회원탈퇴 시 거래기록 보존 – 전자상거래법 §6(5년) vs PIPA §37 충돌"
- `models/user.py:53-62` – 정통방법 §50 ① marketing-consent timestamp 필드는 추가됨 (soft-delete 인프라는 미구현 상태).

c. 판단 요청

- (1) 권장 정책: 회원탈퇴 시 즉시 파기(PIPA) vs 결제기록만 별도 5년 보존(전자상거래법) – 어느 쪽이 우선하는지.
- (2) 권장 구현: hard delete vs soft delete + 결제 테이블만 분리 보존(이메일·이름은 익명화).
- (3) 약관·처리방침에 명시할 정확한 문구 권고.
- (4) **위험 등급 (회사 자체)**: MEDIUM (사용자 PIPA 민원 시 다툼 가능).

Q7. 외부 데이터 라이선스 (FMP / KIS / Alpaca / SEC EDGAR)

a. 현재 포지션

- FMP Premium \$29/mo (750 req/min) – 회사 키 사용. UI에서 시세·펀더멘털·시그널 형태로 가 공개 표시.
- KIS – 사용자 BYOK + read-only. 사용자가 자기 키로 자기 계좌 데이터를 조회.
- Alpaca – 사용자 BYOK. 시스템 키는 ALPACA_ENABLED=0 (production OFF).
- SEC EDGAR Form 4 – 공개 데이터, `insider_mirror_service.py` 에서 가공.

b. 증거

- `frontend/src/content/terms-ko.md:181-184` (제9조 2-3항):

서비스에서 제공되는 시세 데이터 및 펀더멘털 데이터는 **Alpaca, Korea Investment & Securities(KIS), Financial Modeling Prep(FMP)** 등 제3자 데이터 제공자의 라이선스를 기반으로 제공되며, 각 제공자의 이용 조건이 적용됩니다.

외부 데이터 제공자 BYO(Bring Your Own Key) 원칙 ... 회사는 해당 데이터를 자체적으로 재배포 포함하지 않으며 ...

c. 판단 요청

- (1) FMP Premium 약관(회사 키)으로 가공·표시한 데이터를 SaaS 유료 사용자에게 제공하는 것이 "재배포(redistribution)"에 해당하는지.
- (2) KIS Open API 약관에 "본인 계좌 외 사용 금지" 조항이 있는데, 회사가 사용자 위임으로 read-only 조회하는 것이 위반인지.
- (3) Alpaca BYOK 모델이 Alpaca 약관(US Securities firm) 위반 가능성.
- (4) SEC EDGAR Form 4 가공 PDF 배포가 SEC 가이드라인 위반인지.
- (5) 위험 등급 (회사 자체) MEDIUM (라이선스 분쟁은 통상 cease-and-desist로 시작, 즉시 섯 다운 X).

Q8. user_agent_audit 2년 보존 의무 vs CASCADE 충돌 (PR #96 보류)**a. 현재 포지션**

- migration 010_user_agent_audit.py 가 Journal Companion 산출물의 2년 보존을 위해 별도 테이블 생성.
- 회원탈퇴 시 users 테이블 cascade delete가 audit 행을 함께 삭제하면 보존 의무 위반.
- PR #96 보류 상태(HANDOVER_2026-05-04.md:63 "PR #96 보류").

b. 증거

- migrations/versions/010_user_agent_audit.py:2 :

user_agent_audit – Journal Companion 2-year regulatory retention table.

- migrations/versions/010_user_agent_audit.py:19-32 :

than 2 years. Index idx_user_agent_audit_purge keeps that delete ...
revision = "010_user_agent_audit"

c. 판단 요청

- (1) Journal Companion(AI 산출물 audit log)의 2년 보존 의무 법적 근거가 무엇인지(전자금융거래법 §22 vs 자본시장법 §401).
- (2) 회원탈퇴 시 user_id를 NULL로 익명화하고 audit row만 보존하는 방식이 PIPA 적합한지.
- (3) 2년 만료 후 자동 purge index가 적정한지.
- (4) 위험 등급 (회사 자체) LOW-MEDIUM (audit log 누락은 평소엔 문제없으나, 분쟁 발생 시 회사 입증 자료 손실).

Q9. F5 AI Twin rationale leak (paper trade)**a. 현재 포지션**

- F5 AI Twin은 사용자 페르소나(8개 투자자 유형) 기반 페이퍼 트레이딩 시뮬레이션.
- HANDOVER 권고: BUY rationale 에 safe_scrub 적용.
- 2026-05-04 자율 세션 중 수정 적용 – PR #116 (fix/twin-rationale-safe-scrub-2026-05-04, commits 907539f + 1100f6d).

b. 증거 (수정 후 상태, 변호사 미팅 시점 – 직접 grep 검증 2026-05-04)

```
$ grep -nE "from services.legal_filter|safe_scrub|persona=\\{persona\\}|paper exit|cand.rationale" servi
41:from services.legal_filter import safe_scrub # ← 추가됨
226:         rationale=f"persona={persona}; engine={rationale}",
305:         rationale=f"paper exit - persona={persona}; {reason}",
401:         rationale=safe_scrub(cand.rationale, context="twin.buy.rationale"),
```

- BUY path (line 401) - `safe_scrub` 적용 □
- SELL path (line 305) - `f"paper exit - persona={persona}; {reason}"` 이며 `reason` 은 `"TP hit"/"SL hit"/"Time stop"` 같은 결정성 내부 라벨만 사용. AI/엔진 텍스트 미포함 → 의도적 미적용 (회사 판단).
- BUY rationale 출처(line 226) - `f"persona={persona}; engine={rationale}"`. 이 줄 자체는 scrub 안 했지만, 최종 DB write 직전(line 401)에서 전체 문자열에 적용됨.
- 회귀 가드 테스트 추가 - `tests/`
`test_ai_twin.py::test_buy_rationale_is_scrubbed_at_write_time` (poisoned signal "BUY signal - recommended" 입력 → 두 토큰 모두 persisted rationale 에서 제거 검증, 실제 PASS).

c. 판단 요청

- (1) 페이퍼 트레이딩 결과(paper book)에 표시되는 rationale이 "투자 권유"로 해석될 위험. 수정 후에도 변호사 사인 필요.
- (2) `safe_scrub` 적용 여부와 별개로, 페이퍼 트레이딩 자체가 §101 면제 트랙 안에 있는지(시뮬레이션 + 자기 데이터 한정).
- (3) SELL rationale을 의도적으로 scrub 미적용한 회사 판단(내부 라벨만 사용)이 충분한지.
- (4) 위험 등급 (회사 자체, 수정 후) LOW (BUY 경로 hardening 완료 + 회귀 가드 추가). 수정 전: MEDIUM.

Q10. F24 Persona Mentor Match (Tier 4, 사용자-사용자 매칭)

a. 현재 포지션

- 미구현(Tier 4 backlog) - 같은 페르소나 사용자끼리 매칭하여 자기 매매 회고 공유.
- 이 기능이 출시되면 P2P 형태 - "다른 사용자의 매매 의견" 노출.

b. 증거

- 코드 미존재 (회사 자체 평가).
- HANDOVER 명시 의도 - 변호사 사전 검토 후 구현 결정.

c. 판단 요청

- (1) 사용자-사용자 매매 의견 공유가 §101 "불특정 다수 대상 정보 제공"으로 해석될 위험.
- (2) "Mentor Match" 라벨링이 투자권유 해석 가능성을 높이는지.
- (3) 출시 전 어떤 조건(익명화 / 게시판 형태 / 1:1 차단 / 면책 클릭) 충족 시 가능한지.
- (4) 위험 등급 (회사 자체): HIGH (출시 시 §101 위반 직접 트리거 가능).

Q11. 부친 명의 사업자등록 vs 본인 명의

a. 현재 포지션

- CEO(배상현, 1인 창업자)는 현재 취준생 신분.

- 사업자등록을 부친 명의로 할 가능성 검토 중.
- 통신판매업 신고는 사업자등록 후 가능.

b. 증거

- HANDOVER_2026-05-04.md:21-24: "사업자등록 + 통신판매업 신고 후: BUSINESS_REGISTRATION_NUMBER set / TELESELLER_REGISTRATION_NUMBER set"
- frontend/src/content/privacy-ko.md:11 : operator: "배상현 (예정 사업자등록자)"

c. 판단 요청

- (1) 부친 명의 사업자등록 시 자본시장법 위반(예: §101 면제 트랙) 사인이 부친 명의로 들어가는 리스크.
- (2) 운영 실체와 사업자 명의를 다를 경우 PIPA 정보주체 청구 시 책임 분배(부친 vs 본인).
- (3) 본인 명의로 사업자등록 가능 여부(취준생 신분 + 부모 의료보험 피부양자 등 조건 영향).
- (4) 세무: 부친 명의 시 부친 종합소득세 영향, 본인 명의 시 4대보험 의무.
- (5) 위험 등급 (회사 자체): HIGH (잘못 결정 시 부친 신용·세무 영향).

Q12. 표시광고법 §3 (기만표시) – Template Hardcoding Guard

a. 현재 포지션

- 회사는 샘플/시뮬레이션 데이터에 실제 종목 ticker / 금액을 하드코딩하지 않는 정책.
- CI legal-guard workflow + pytest로 자동 검증, 현재 0건 위반.

b. 증거

- CLAUDE.md (Template Hardcoding Guard 섹션):
방어선 2개 (이중 방어): CI legal-guard / 로컬 pytest.
PR 머지 전 CI legal-guard job 이 green 이어야 머지 가능.
- .github/workflows/legal-guard.yml + tests/test_no_hardcoded_samples.py.

c. 판단 요청

- (1) "예시 화면"의 가짜 ticker(AAPL, TSLA 등)/금액 표시가 표시광고법 §3 (기만표시) 위반인지.
- (2) "PRO 배지", "Premium 기능" 표시가 광고 표시 의무 위반인지.
- (3) 백테스팅 결과의 "과거 수익률" 표시가 자본시장법 §178(시세조작 금지)·표시광고법 §3 모두 트리거하는지.
- (4) 추가 권고 문구.
- (5) 위험 등급 (회사 자체): LOW-MEDIUM.

§3 약관/처리방침 인라인 검토 요청

3-1. 이용약관 (terms-ko.md) – 13개 조항

조	라인	핵심 한 줄	변호사 검토 포인트
제1조 (목적)	32-37	이용약관 → 회사·이용자 권리·의무·책임 사항	표준
제2조 (용어의 정의)	38-50	회사/회원/서비스/시그널/AI Assistant 정의	"시그널" 정의에 "투자권 유 아님" 명시 가능 여부
제3조 (약관의 효력 및 변경)	51-59	30일 사전 공지 후 변경 가능	약관규제법 §3 부합
제4조 (회원가입 및 자격)	60-71	OAuth 기반, 만 14세 미만 가입 불가	미성년자 보호 조항 추가 검토
제5조 (회원의 의무)	72-86	허위정보 금지, 타인 명의 도용 금지	표준
제6조 (서비스 이용 – 투자자문 면책)	89-112	자본시장법상 투자자문업자 아님 명시	핵심 면책 – Q1 참조
제7조 (시그널 및 AI Assistant 면책)	115-139	POSITIVE/NEGATIVE/NEUTRAL은 분석 결과, 추천 아님	핵심 면책 – Q1·Q9 참조
제8조 (유료 서비스)	142-176	9,900 / 19,900원, Stripe, 14일 청약철회	전자상거래법 §17 부합 검토
제9조 (콘텐츠 저작권)	178-185	BYOK 원칙 명시, 재배포 금지	Q7 참조
제10조 (회원의 책임)	188-194	계정 관리, 자기 책임	표준
제11조 (회사의 책임 제한)	197-216	손실 책임 부담 안 함, 간접손해 제외	약관규제법 §7 (불공정 약관) 적합 검토
제12조 (분쟁 해결)	217-225	한국법, 서울중앙지법 관할	표준
제13조 (문의처)	226-234	support@pivoxquant.com	시행일·사업자번호·연락처 확정 필요
부칙	235-244	시행일자	DRAFT → ACTIVE 시 시행일 기재

→ Q5 참조.

3-2. 개인정보처리방침 (privacy-ko.md) – 12개 조항

조	라인	핵심 한 줄	변호사 검토 포인트
제1조 (수집하는 개인정보 항목)	41-85	이메일/이름/OAuth 토큰/결제정보 (Stripe) 등	수집 항목 최소화 원칙
제2조 (개인정보 수집 방법)	86-97	OAuth, 회원가입, 결제 시 수집	표준
제3조 (개인정보 수집 및 이용 목적)	98-113	서비스 제공, 결제, 공지, 마케팅	정통방법 §50 별도 동의 분리
제4조 (개인정보 보유 및 이용 기간)	114-140	항목별 보유기간	Q6 참조 (전자상거래법 §6 vs PIPA §37)
제5조 (개인정보의 제3자 제공)	141-174	원칙적 제공 X, 법령 요구 시 한정	표준
제6조 (개인정보 처리 위탁)	175-211	Stripe/Anthropic/Vercel/Railway/Google/Kakao	핵심 – Q4 참조
제7조 (정보주체의 권리 및 행사 방법)	213-239	열람/정정/삭제/처리정지	PIPA §35-37 부합
제8조 (쿠키 사용)	240-259	쿠키 동의 배너 운영	정통방법 §50 부합
제9조 (개인정보의 안전성 확보 조치)	260-282	TLS 1.3, 접근통제, 암호화	PIPA §29 부합
제10조 (개인정보 보호책임자 / DPO)	283-306	보호책임자 = 배상현(예정)	1인 운영 – 별도 DPO 지정 의무 여부
제11조 (변경 고지)	307-327	변경 7일 전 공지	표준
제12조 (문의처)	328-337	privacy@pivoxquant.com	표준
부칙	338-346	시행일자	DRAFT → ACTIVE 시 시행일 기재

→ Q4·Q6 참조.

§4 자료 부록 – 핵심 코드 스니펫

4-1. 면책·치환 코어 (services/legal_filter.py)

항목	위치	갯수/길이
파일 전체	services/ legal_filter.py	344 lines
re.compile 총 패턴 수	grep -c "re\.compile"	96
_REPLACEMENTS (surgical 치환)	line 36-155	89 patterns
_PROHIBITED_PATTERNS (구조적 위반 – 로그 경고)	line 159-166	6 patterns
_COMPLIANCE_FORBIDDEN_PATTERNS (hard deny-list)	line 312-321	14 raw patterns (한국어 13 + 영문 alternation 1)
_DISCLAIMER_KR/EN (자동 첨부)	line 169-170	2개 문구
_SCRUB_FIELDS (cache write path 검사 대상)	line 173-191	17 fields

발췌 (line 36-50):

```
_REPLACEMENTS: list[tuple[re.Pattern[str], str]] = [
    # — Group 1: 복합 구문 (우선 처리) —————
    (re.compile(r"포지션\s*축소\s*또는\s*청산\s*고려"), "약세 신호 감지 (정보 제공)"),
    (re.compile(r"노출\s*축소\s*(권고|권장)"), "노출 지표 상승 관찰"),
    ...
    # — Group 2: 권고 / 권장 / 추천 (단일 동사) —————
    (re.compile(r"매수\s*(권고|권장|추천)"), "정보 고지 (사전 설정 레벨 도달)"),
    (re.compile(r"매도\s*(권고|권장|추천)"), "정보 고지 (사전 설정 레벨 도달)"),
    ...
]
```

발췌 (line 159-166, _PROHIBITED – 6 패턴):

```
_PROHIBITED_PATTERNS: list[re.Pattern[str]] = [
    re.compile(r"목표가\s*[\$₩]?[\s*[\d,\.]+"),
    re.compile(r"예상\s*수익률\s*[+-]?[d+(\.\d+)?%"),
    re.compile(r"적정가\s*[\$₩]?[\s*[\d,\.]+"),
    re.compile(r"price\s*target[:\s]*[\$]?[\d,\.]+", re.IGNORECASE),
    re.compile(r"expected\s*return[:\s]*[+]?[d+(\.\d+)?%", re.IGNORECASE),
    re.compile(r"fair\s*value[:\s]*[\$]?[\d,\.]+", re.IGNORECASE),
]
```

발췌 (line 312-321, _COMPLIANCE – hard deny):

```

_COMPLIANCE_FORBIDDEN_PATTERNS = [
    r"추천", r"조언", r"권(?:고|유|장)",
    r"매수", r"매도",
    r"사세요", r"파세요", r"사라", r"팔아",
    r"오를\s*것", r"내릴\s*것", r"오른다", r"내린다",
    r"\b(?:buy|sell|recommend|advise|advise)\b",
]

```

4-2. 단어 deny-list 정전(canonical) (services/legal/forbidden_terms.py)

항목	값
파일 라인 수	115
FORBIDDEN_DIRECTIVE_TERMS 토큰 수	20 (frozenset 직접 카운팅)
영문 단일 토큰 (8)	buy / sell / hold / recommend / recommendation / advice / advise / advisor
영문 복합 (4)	buy recommendation / sell recommendation / ai coach / investment coach
한국어 토큰 (8)	추천 / 조언 / 투자 코치 / 매수 / 매도 / 매수 추천 / 매도 추천 / 보유 하세요

발췌 (line 53-79):

```

FORBIDDEN_DIRECTIVE_TERMS: Final[frozenset[str]] = frozenset({
    "buy", "sell", "hold", "recommend", "recommendation",
    "advice", "advise", "advisor",
    "buy recommendation", "sell recommendation",
    "ai coach", "investment coach",
    "추천", "조언", "투자 코치",
    "매수", "매도", "매수 추천", "매도 추천",
    "보유하세요",
})

```

주: 위 frozenset 정확히 20개 토큰 (영문 12 + 한국어 8). 회사 자체 카운팅이며 변호사가 직접 확인 시 grep 결과 인용.

4-3. DisclaimerBanner UI 컴포넌트

항목	값
컴포넌트 파일	frontend/src/components/ui/disclaimer-banner.tsx
사용처 grep -l 결과	30개 .tsx 파일 (대시보드 layout 글로벌 적용 + 각 분석 페이지)
핵심 사용처	(dashboard)/layout.tsx (글로벌), ai-chat, ai, portfolio, market, pre-trade, watchlist, reports, companion, home, signals, alerts, detail/[ticker], risk 외
추가 위치	frontend/src/lib/reports/disclaimer.ts (PDF 산출물 disclaimer 헬퍼)

4-4. KIS read-only 강제 (services/kis/service.py:489-528)

```
def buy_order(self, ticker: str, quantity: int, price: int = 0, order_type: str = "00"):
    """DISABLED -- KIS order execution is read-only for legal compliance.
    한투 주문 실행은 투자일임업(자본시장법) 규제에 영구 비활성화됨.
    """
    return {
        "ok": False,
        "error": "KIS order execution is disabled. Please use the KIS app to place orders.",
    }

# 동일 패턴 sell_order(:503), _place_order(:517)
```

4-5. ALPACA_ENABLED kill switch (config.py:45-69 + routes/broker_oauth.py:255-453)

```
# config.py:45-69
# ALPACA_ENABLED -- kill switch for SYSTEM-WIDE Alpaca usage (server-owned keys).
# This server-side ALPACA_ENABLED flag therefore stays OFF in production.
ALPACA_ENABLED = os.environ.get("ALPACA_ENABLED", "0").strip() in ("1", "true", "True", "TRUE", "yes")

# routes/broker_oauth.py:309-327
def _alpaca_kill_switch_response():
    """Return the standard 503 payload for disabled Alpaca endpoints."""
    if current_app.config.get("ALPACA_ENABLED"):
        return None
    return jsonify({"ok": False, "code": "alpaca-disabled", ...}), 503
```

4-6. autotrader 비활성 (routes/__init__.py:14-22, 71)

```
from .trades import trades_bp
# REMOVED 2026-04-27 per CEO + legal: autotrader blueprint disabled
# (자동매매 기능 제거 – 투자일임업 등록 회피).
# File routes/autotrader.py preserved for rollback. To restore:
# 1) Re-add: from .autotrader import autotrader_bp
# 2) Re-add autotrader_bp to the blueprints list below.
# 3) Re-enable autotrader.py worker boot in app.py.
# from .autotrader import autotrader_bp
...
blueprints = [
    ...
    # REMOVED 2026-04-27 per CEO + legal: autotrader_bp,
    ai_bp, watchlist_bp, ...
]
```

4-7. 회색지대 5 PDF – 자기 데이터 분기

```
services/artifacts/year_end_letter_service.py:456
    def generate_for_user(self, user_id: int, target_year=None) ...

services/artifacts/earnings_prebrief_service.py:6, 154
    EarningsPreBriefService().generate_for_position(user_id, ticker, earnings_date)

services/artifacts/credit_rating_service.py:5
    CreditRatingService().generate_for_user(user_id, as_of=None) → data dict

services/artifacts/insider_mirror_service.py:9, 27
    P1 Weekly summary – count of filings related to holdings.
    APScheduler day_of_week=mon, hour=9 KST. Empty holdings → ...

services/artifacts/pre_trade_checklist_service.py:1-3
    """Pre-Trade Checklist – persona-tailored 7-question self-check.
    매매 전 **자기점검용 양식** (Tools, not advice). 사용자가 직접 ..."""
```

4-8. F5 AI Twin rationale – safe_scrub 적용 (Q9, PR #116 머지 후 변호사 미팅 시점)

```
$ grep -nE "from services.legal_filter|safe_scrub|persona=\\{\\{persona\\}\\}|paper exit|cand.rationale" servi
41:from services.legal_filter import safe_scrub # ← 추가됨
221:    rationale = str(result.get("signal") or result.get("rationale") or "engine")
226:    rationale=f"persona={persona}; engine={rationale}",
305:    rationale=f"paper exit – persona={persona}; {reason}",
401:    rationale=safe_scrub(cand.rationale, context="twin.buy.rationale"),
```

- BUY 경로 (line 401) safe_scrub 적용 □
- SELL 경로 (line 305) 미적용은 의도적: reason 이 결정성 내부 라벨("TP hit (+12.5% >= +12.0%)")만 사용하므로 advisory leak 경로 없음.
- 회귀 가드: tests/test_ai_twin.py::test_buy_rationale_is_scrubbed_at_write_time ("BUY signal – recommended" poisoned signal → 두 토큰 모두 persisted rationale 에서 제거 검증).

§5 자문 후 follow-up 작업 리스트

변호사 답을 받은 후 CEO가 즉시 진행할 작업:

5-1. ACTIVE 전환 (변호사 사인 받은 직후)

- [] `terms-ko.md:7` `status: "DRAFT"` → `status: "ACTIVE"` - 시행일 YYYY-MM-DD
- [] `privacy-ko.md` 동일 처리 (시행일 기재)
- [] 사업자등록번호 / 통신판매업 신고번호 / 개인정보 보호책임자 연락처 부칙·제13조·제10조에 기입

5-2. 누락 보완 (Q4 사인 후) - 선제 적용 완료 (commit `c9c6827`, 2026-05-05)

- [x] signup 화면 5번째 체크박스 추가: "국외 이전 동의 (PIPA §28-8)"
- [x] frontend `signup/_v2/page-v2.tsx` Consents 타입 + UI + localStorage payload 갱신
- [x] backend `routes/consents.py` 에 GET / POST / DELETE `/api/consents/cross-border` 추가 (migration 024 + 컬럼은 2026-05-03 사전 적용됨)
- [x] frontend/src/lib/consents.ts `flushPendingCrossBorderConsent()` 헬퍼 추가
- [x] dashboard layout에서 OAuth 콜백 후 자동 flush
- [x] `privacy-ko.md` `<a id="cross-border">` anchor 추가
- [] (Q4 사인 후) 변호사 권고 시 settings 페이지에 cross_border opt-out 토글 UI
- [] (Q4 사인 후) 미국 위탁처로 데이터 보내기 전 runtime 가드 적용 (별도 PR - 본 commit은 동의 기록 계층만)
- [] (Q4 사인 후) `terms-ko` §6-1 "이용 시 동의로 간주" 표현 → "별도 명시 동의" 으로 정정

5-3. F5 AI Twin rationale 보완 (Q9 사인 후) - 선제 적용 완료 (commit `91fd01c` merge)

- [x] BUY 경로 (`services/twin/twin_runner.py:401`) `safe_scrub(cand.rationale, ...)` 적용
- [x] `tests/test_ai_twin.py::test_buy_rationale_is_scrubbed_at_write_time` 회귀 가드 추가
- [x] `fix/twin-rationale-safe-scrub-2026-05-04` 브랜치 main 머지 완료
- [] (변호사가 SELL 경로 scrub 요구 시) `services/twin/twin_runner.py:305` 에 `safe_scrub(reason, context="twin.sell.reason")` 적용 - 현재 미적용은 의도적 (SELL reason 은 결정성 내부 라벨만 사용)
- [] (옵션) line 226 `engine={rationale}` 단계에서 사전 scrub 추가 (방어 깊이 hardening)

5-4. 회원탈퇴 정책 결정 (Q6 사인 후)

- [] hard delete vs soft delete + 결제 분리 보존 결정 후 구현
- [] `models/user.py` 에 `deleted_at` 컬럼 + soft-delete migration

- [] 결제 테이블 분리 보존 (이메일·이름 익명화)

5-5. user_agent_audit (Q8 사인 후)

- [] PR #96 재개 또는 신규 PR – cascade 충돌 방지 로직(user_id NULL 익명화 + audit 보존)

5-6. F24 Persona Mentor Match (Q10 사인 후)

- [] 사인 받은 조건(익명화 / 게시판 / 면책) 충족하는 설계 시 backlog → roadmap

5-7. 사업자등록 (Q11 사인 후)

- [] 명의(부친 vs 본인) 결정 후 사업자등록 + 통신판매업 신고
- [] Railway env에 BUSINESS_REGISTRATION_NUMBER, TELESELLER_REGISTRATION_NUMBER set
- [] PR #74 결제 가드(payment guard) 자동 활성화

5-8. 마이데이터 (Q3 사인 후)

- [] 사인 결과 반영하여 약관 제9조 BYOK 문구 보강
- [] (인가 필요로 판정 시) 서비스 모델 재설계 – KIS broker 기능 제거 또는 user-side만 유지

5-9. 데이터 라이선스 (Q7 사인 후)

- [] FMP 약관 재검토 + 회사 키 재배포 우려 조항 검토
- [] KIS Open API 약관 검토
- [] (필요 시) FMP 키도 BYOK 모델로 전환

5-10. 추가 일반

- [] DPO 지정 (회원 1,000명 이상 시 의무 – legal_compliance.md:36-39)
- [] 금융감독원 핀테크 혁신지원 사전 문의 (규제 샌드박스 가능성)
- [] 변호사 추가 자문 일정 – 사업자등록 후 1회 / MAU 1,000명 도달 시 1회

§6 검증 로그 (10 verifications, grep/test 직접 실행)

각 항목은 2026-05-04 본 패키지 작성 직전 grep / wc / find / Read 도구로 직접 검증한 결과다.

#	검증 대상	명령	결과	인용 위치
1	legal_filter.py 라인 수 + 정규식 패턴 수	wc -l services/ legal_filter. py / grep -c "re\\.compile"	344 lines / 96 re.compile (89 _REPLACEMENTS + 6 _PROHIBITED + 1 _COMPLIANCE)	§4-1
2	forbidden_terms. py 토큰 수	wc -l services/ legal/ forbidden_ter ms.py / Read	115 lines / 20 tokens (frozenset, 영문 12 + 한국어 8)	§4-2
3	DisclaimerBanner 컴포넌트 위치 + 사용 처	find ... -name disclaimer- banner / grep -l DisclaimerBan ner ... \\ wc -l	컴포넌트: frontend/src/components/ui/ disclaimer-banner.tsx / 사용처: 30 개 .tsx 파일 (대시보드 layout 글로벌 적용 포함)	§4-3
4	autotrader 등록 해 제 여부	ls / autotrader.py / grep autotrader routes/ __init__.py	루트 autotrader.py 존재하지 않음 / rout es/__init__.py:16-22 주식 처리 + line 71 blueprints 리스트에서 제거	§1-2, §4-6
5	ALPACA_ENABLED kill switch 위치	grep -nE "_alpaca_kill_ switch_respon se\\ ALPACA_ENABLED " routes/ broker_oauth. py	config.py:45-69 (선언) / routes/ broker_oauth.py 6곳 적용: 정의 line 309-327 + status endpoint 가드 line 260 + endpoint 가드 4곳 (365 / 414 / 435 / 451) / tests/ test_alpaca_kill_switch.py (회귀 테스 트)	§1-4, §4-5
6	KIS read-only 검 증	grep -nE "order\\ 주문\\ buy\\ sell" services/kis/ service.py	buy_order(:489) / sell_order(: 503) / _place_order(:517) 3개 함수 모 두 DISABLED 상태 + 자본시장법 사유 docstring 명시 / get_order_status(: 532) 는 조회 전용	§1-3, §4-4
7	terms-ko.md DRAFT 워터마크 위치	grep -n DRAFT terms-ko.md	line 7: status: "DRAFT – 최종 시행 전 변 호사 검토 필요"	§3-1
8	privacy-ko.md 국 외 이전 조항 위치	grep -nE "국외 \\ 이전\\ 미국\\ Anthropic" privacy-ko.md	line 175-211 (제6조 위탁 + 제6조 ① 국외 이전 표) – Stripe(US) / Anthropic(US) / Railway(US Oregon) / Vercel(US) / Google LLC(US) / Kakao(KR, 위탁)	§2 Q4, §3-2

#	검증 대상	명령	결과	인용 위치
9	회색지대 5 PDF 자기 데이터 분기	<code>find services/artifacts/ -name "*.py" +</code> 각 파일 내부 grep	<code>generate_for_user(user_id)</code> <code>(year_end_letter:456 /</code> <code>credit_rating:5) / generate_for_pos</code> <code>ition(user_id, ticker)</code> <code>(earnings_prebrief:6) / holdings 기</code> <code>반 (insider_mirror:9, 27) /</code> <code>persona-tailored self-check</code> <code>(pre_trade_checklist:1-3). 모두</code> user_id 인증 필수.	§2 Q2, §4-7
10	F5 AI Twin rationale safe_scrub 적용 여부	1차 grep (변호사 패키지 작성 중) → 미적용 0건 확인. 2차 검증 (수정 후, audit agent 정정) → <code>services/twin/twin_runner.py</code> :41 import 추가, line 401 <code>safe_scrub(cand.rationale, context="twin.buy.rationale")</code> 적용.	수정 적용 – PR #116 (commits 907539f + 1100f6d). BUY 경로 hardening + 회귀 가드 테스트 (<code>test_buy_rationale_is_scrubbed_at_write_time</code>) PASS. SELL 경로 미적용은 의도적(내부 deterministic 라벨만 사용).	§2 Q9, §4-8

6-1. 추가 검증 – 메모리 vs 코드 불일치 (투명성)

메모리 기재	실제 코드	본 패키지 처리
<code>legal_compliance.md:21-23</code> "이용약관 18개 조항"	<code>terms-ko.md</code> 실제 13개 조항(1~13조 + 부칙)	§3-1 표에 13개로 사실 기재
<code>legal_compliance.md:21-23</code> "처리방침 14개 조항"	<code>privacy-ko.md</code> 실제 12개 조항(1~12조 + 부칙)	§3-2 표에 12개로 사실 기재
메모리 stale 마커	시스템에서 "6 days old, may be outdated" 명시	코드 grep 결과 우선
사용자 컨텍스트 "forbidden_terms.py 22 토큰"	실제 frozenset 20 tokens (영문 12 + 한국어 8)	§4-2 표에 20으로 사실 기재

6-2. 검증 BLOCKED 항목 (변호사 답 필요)

본 패키지는 **사실 기술서**이므로 다음은 회사 자체 판단 불가:

- Q1 면제 적정성 (변호사 답 필요)
- Q3 마이데이터 인가 필요 여부 (변호사 답 필요)
- Q4 §28-8 별도 동의 충족성 (변호사 답 필요)

- Q6 PIPA §37 vs 전자상거래법 §6 우선 (변호사 답 필요)
 - Q11 부친 명의 vs 본인 명의 (변호사 + 세무사 답 필요)
- 본 패키지 §2의 Q1~Q12 모두 "회사 자체 평가 위험 등급"만 기재했고, 최종 사인은 변호사 책임.
-

§7 본 패키지 사용법 (CEO 메모)

7-1. 변호사 미팅 전 (CEO 사전 작업)

1. 본 패키지 §0~§5 출력본 1부 + USB(코드 raw 접근용) 1개 준비
2. 사업자등록 의향(부친 vs 본인) 사전 결정 또는 변호사에게 두 옵션 모두 질의
3. 미팅 1시간 전 §2의 12개 질문을 한 번 더 확인
4. 미팅 비용(50~80만원) 견적 사전 합의

7-2. 미팅 중

- 각 Q1~Q12에 대해 변호사가 답한 내용을 본 패키지 우측 빈 칸 또는 별도 노트에 기록
- 위험 등급(Low/Medium/High)을 변호사가 재평가하면 회사 자체 평가와 차이를 추적
- 변호사가 "추가 자료 필요"로 보류한 항목은 별도 follow-up 리스트로 분리

7-3. 미팅 후

- 위 §5 follow-up 작업 리스트를 변호사 사인 결과대로 우선순위 재배치
- 사인 받은 항목은 즉시 메모리 `legal_compliance.md` 갱신
- 다음 자문 일정 합의 (MAU 1,000명 도달 시 / 사업자등록 직후 / 매년 1회)

7-4. 본 패키지 신뢰성 보증

- 본 패키지의 모든 코드 인용은 **file:line** 형식이며, 변호사가 직접 `git clone` 후 검증 가능
 - 메모리(stale 가능)와 코드(실제 사실)이 충돌할 경우 **코드 우선**
 - "추측"이라고 표시되지 않은 모든 사실 진술은 `grep / wc / find / Read` 도구로 직접 검증된 것
 - 회사 자체 평가(위험 등급)는 보수적으로 기재 – 변호사 의견과 차이 발생 시 변호사 의견 우선
-

§8 변경 이력

버전	날짜	변경
v1	2026-04-22	초안 작성 (537 lines)
v2	2026-05-04 (자율 세션 1차)	갱신: 유사투자자문업 미등록 결정 반영 / 5 PDF 자기 데이터 분기 검증 / signup 5번째 체크박스 누락 명시 / KIS read-only 라인 검증 / Alpaca kill switch 위치 검증 / F5 AI Twin rationale 미적용 상태 명시 / 메모리 vs 코드 차이 표(13조 vs 18조) 투명 기재 / 10가지 grep 검증 로그 추가
v2.1	2026-05-04 (자율 세션 2차)	F5 AI Twin rationale 수정 반영 – PR #116 (commits 907539f + 1100f6d)으로 services/twin/twin_runner.py:401 에 safe_scrub(cand. rationale, context="twin.buy.rationale") 적용 + 회귀 가드 테스트 추가. Q9 위험 등급 MEDIUM → LOW. §6-10 검증 로그 갱신. v2 작성 시 grep 결과는 수정 적용 직전 상태였음 (작업 시간 차이) – 수정 후 grep 으로 재검증함.
v2.2	2026-05-04 (자율 세션 audit pass)	audit agent 정정 6건 반영 : (1) twin_runner.py 라인 번호 정확화 (import line 41, BUY scrub line 401, rationale lines 226/305) – 수정 후 직접 grep 으로 재확인. (2) routes/broker_oauth.py "9곳" → 6 곳 (정의 309-327 + status 가드 260 + endpoint 가드 4곳: 365/414/435/451). (3) forbidden_terms.py 토큰 22 → 20 (영문 12 + 한국어 8) – frozenset 직접 카운팅. 한국어 (10) → (8). (4) _COMPLIANCE_FORBIDDEN_PATTERNS "9 advisory verbs" → "14 raw patterns (한국어 13 + 영문 alternation 1)". (5) §5-3에 v2.1 컨텍스트 단서 추가. (6) §4-8 제목 "미적용 (Q9)" → "적용 (Q9, PR #116 머지 후 변호사 미팅 시점)" 으로 정정. §101 "면제 트랙" 표현은 변호사가 직접 정정 가능하므로 미수정 (Q1에서 사인 받기).
v2.3	2026-05-05 (자율 세션 – sync with reality)	선제 적용 3건 반영 – v2.2 미팅 직전이라 변호사 사인 전에 코드 적용을 마쳤음. (A) safe_scrub 머지 완료 – fix/twin-rationale-safe-scrub-2026-05-04 브랜치 main 머지(merge commit 91fd01c). v2.1/v2.2의 "PR open" 표현이 이제 "main 머지됨"으로 사실화. Q9 위험 LOW (사실). (B) autotrader 물리 삭제 (commit 4bcc9ab) – services/trading/autotrader.py 1,321 lines + routes/autotrade.py 279 lines + container/app/routes/__init__의 잔존 주석 6 파일 모두 제거. tag legal-pre-autotrader-removal (push 됨) 만 rollback 경로. §1-2 표 + §4-6 갱신. (C) signup cross_border 체크박스 (commit c9c6827) – frontend/src/app/(auth)/signup/_v2/page-v2.tsx 5번째 [필수] 체크박스 추가, frontend/src/lib/consents.ts 4 helpers 추가, routes/consents.py 3 endpoints 추가, dashboard layout 자동 flush. §5-2 [x] 처리 + §2 Q4 본문 갱신. (D) leftover tests/test_autotrade_smoke.py 삭제 (commit d8088c7).

– 끝.